

Investment Memo

Quantified Risk Treatment Decision — GRC Advanced 4

Intern code: UBI-2026-0038 | Project: GRC-A4 | Variant: V8

Evidence marker: UBI-A8-68E05244B5C7 | Budget cycle: \$75,000

1. Recommendation

Fund exactly three treatments this cycle for a combined cost of \$21,000 against the \$75,000 budget, reducing mean annualized loss exposure by approximately \$1,547,601 — roughly 41% of total mean inherent loss across all 12 identified risks, for under 28% of the available budget.

Asset	Threat	Cost	Mean risk reduction	Remediation
files-01	SMB signing not required	\$6,000	\$327,315	require signing and test legacy clients
backup-01	Management interface accessible from user VLAN	\$6,000	\$1,142,977	restrict to management VLAN and MFA
db-reporting	TLS certificate expires in 12 days	\$9,000	\$77,309	renew and automate expiry alert

2. Why these three, not others

Treatment selection is not a subjective ranking — it is the output of a budget-constrained optimizer (risk-model/treatment_selection.py, validated against 8 published fixtures plus dependency/tie-break/infeasibility unit tests) that considers every combination of exactly 3 treatments within budget and picks the one maximizing total mean risk reduction. No other 3-treatment combination within \$75,000 scores higher than the one selected here.

Two of the three selected treatments (files-01 and backup-01) dominate the reduction total because they address the two assets with the largest records exposure (920,000 each) and the highest business-consequence text in the register — both are config/access-change remediations, meaning low-cost relative to impact. The third (db-reporting's certificate renewal) is a comparatively cheap, high-urgency fix (12 days to expiry) that would otherwise cause an availability incident regardless of its risk-reduction ranking.

3. Deferred (accepted, not funded this cycle)

The remaining 9 risks are not being treated this cycle. This is a budget-prioritization decision, not a judgment that they don't matter — see risk-register.csv's review_trigger column for each one's re-evaluation condition.

Asset	Threat	Treatment cost (if funded)	Mean reduction (if funded)
edge-lab-07	Unsupported web component	\$2,000	\$383
payroll-api-01	Broken object authorization	\$15,000	\$42,230
vpn-gw-01	Outdated VPN appliance	\$9,000	\$4,019
helpdesk-02	Local administrator password reused	\$15,000	\$655
marketing-old	Remote code execution	\$2,000	\$145
idp-01	Admin session timeout exceeds policy	\$15,000	\$8,064
dev-git-01	Inactive deploy key remains valid	\$6,000	\$6,439
dns-01	Recursion available to guest VLAN	\$6,000	\$5,925
print-03	Default management community string	\$6,000	\$128

4. Methodology summary

4.1 Loss and frequency estimation

Frequency (annual rate of occurrence) is derived from CVSS severity plus whether exploit evidence indicates confirmed exploitation versus only configuration review. Loss magnitude combines a conservative \$5/record notification-and-remediation cost with 5% of each asset's stated annual revenue dependency, scaled by asset criticality tier. An earlier draft used the commonly-cited \$150/record industry-average figure and produced loss estimates exceeding \$100M for assets whose largest revenue-dependency figure is \$8.1M identified as disproportionate to this dataset's actual scale and replaced. Full rationale is in `risk-model/build_risk_rows.py`.

4.2 Simulation

Each risk row is simulated with 50,000 Monte Carlo draws (triangular distributions for frequency and loss magnitude, uniform for control effectiveness), seeded deterministically from the evidence marker so the same inputs always reproduce the same outputs. Inherent loss = frequency $\times$ loss magnitude $\times$ dependency multiplier; residual loss = inherent $\times$ (1 – control effectiveness).

4.3 Treatment cost estimation

Treatment costs are bucketed by remediation type (decommission/config-change/patch-upgrade/engineering-change), each with a stated dollar figure and rationale in `risk-model/build_treatments.py` these are documented planning estimates, not vendor quotes, and should be replaced with real quotes before this memo is used for actual budget approval.

5. What this memo does not cover

- Host-hardening evidence (Lynis/OpenSCAP before/after scans) is not yet available — see README.md known limitations. This memo covers only the quantified vulnerability-risk treatment decision, not the separate host-hardening work.
- Treatment costs are planning-level estimates from a documented rule set, not procurement quotes.
- This register does not model attack-chain dependencies between assets (e.g., VPN gateway compromise increasing the likelihood of downstream findings) — each of the 12 risks is treated as independent, a documented simplifying assumption.